

Rencana Pengujian Integrasi Protokol AAA (Testing Plan)

Proyek: Sistem Manajemen Lab & Skrining Awal Tuberkulosis (TBC)
Fokus Pengujian: Keamanan Backend - Otentikasi, Otorisasi, dan Akuntabilitas (AAA)

Pendahuluan

Dokumen ini mendeskripsikan skenario pengujian terstruktur untuk memverifikasi integrasi protokol keamanan AAA (*Authentication, Authorization, Accounting*) pada arsitektur *backend*. Pengujian ini bertujuan untuk membuktikan bahwa sistem dapat mengidentifikasi pengguna secara akurat, membatasi hak akses sesuai wewenang, dan mencatat setiap aktivitas secara permanen guna memenuhi standar nirsangkal (*non-repudiation*).

Rencana Uji Autentikasi (Authentication)

ID	Skenario Pengujian	Langkah Pengujian (Payload/Aksi)	Hasil yang Diharapkan (Ekspektasi)
AU TH-01	Login dengan kredensial valid	POST /api/auth/login dengan <i>email & password</i> benar.	HTTP 200 OK. Mengembalikan token JWT yang valid.
AU TH-02	Login dengan kata sandi salah	POST /api/auth/login dengan kata sandi acak.	HTTP 401 Unauthorized. Login ditolak.
AU TH-03	Akses <i>endpoint</i> tertutup tanpa token	Memanggil GET /api/patients tanpa <i>header</i> Authorization.	HTTP 401 Unauthorized. Akses ditolak.
AU TH-04	Akses dengan token kedaluwarsa	Menggunakan token JWT yang umurnya sudah melewati batas 24 jam.	HTTP 401 Unauthorized. Token ditolak.

AU TH- 05	Mitigasi injeksi SQL pada form login	POST /api/auth/login dengan payload: "email": "admin' OR 1=1 --"	HTTP 401 Unauthorized. Sistem memblokir karakter anomali.
-----------------	---	---	--

Rencana Uji Otorisasi (*Authorization*)

ID	Skenario Pengujian	Langkah Pengujian (Payload/Aksi)	Hasil yang Diharapkan (Ekspektasi)
AUT HZ-0 1	<i>Bypass</i> wewenang beda tingkat	<i>Login</i> sebagai Teknisi Lab, mencoba memanggil GET /api/review/queue (Rute khusus Dokter).	HTTP 403 Forbidden. Akses ditolak lapis <i>Middleware</i> .
AUT HZ-0 2	Isolasi Multitenant (Beda Faskes)	Dokter dari RS "A" mencoba melihat profil Pasien dari RS "B" via GET /api/patients/:id.	HTTP 403 Forbidden. Fungsi assertSameInstitution memblokir akses.
AUT HZ-0 3	Akses file tanpa <i>Presigned URL</i>	Mengakses langsung URL objek citra di Supabase tanpa token URL khusus.	Akses ditolak oleh konfigurasi <i>Bucket</i> (HTTP 4xx).
AUT HZ-0 4	Kedaluwarsa <i>Presigned URL</i>	Mengakses <i>Presigned URL</i> gambar medis yang umurnya melebihi 15 menit.	HTTP 403 Forbidden dari sisi Supabase Storage.

Rencana Uji Akuntabilitas (*Accounting/Traceability*)

ID	Skenario Pengujian	Langkah Pengujian (Payload/Aksi)	Hasil yang Diharapkan (Ekspektasi)
ACC- 01	Pencatatan mutasi entitas Pasien	<i>Login</i> sebagai Operator, lalu POST /api/patients untuk menambah pasien baru.	Database AuditLog bertambah 1 baris. Mencatat user_id, aksi CREATE, entitas Patient.
ACC- 02	Pencatatan pengesahan Laporan	<i>Login</i> sebagai Dokter, lalu melakukan finalisasi dokumen laporan.	Database AuditLog mencatat aksi SIGN_REPORT dengan entity_id yang cocok.

ACC-03	Uji kekebalan (Immutability) Log	Secara programatik memanggil instruksi UPDATE atau DELETE pada baris di tabel AuditLog.	Sistem menolak / tidak menyediakan fungsi API apa pun untuk menghapus log (hanya-tambah).
ACC-04	Pencatatan lalu lintas jaringan	Melakukan <i>request</i> dari Postman, lalu memeriksa panel terminal peladen.	<i>Morgan Logger</i> memunculkan rekaman <i>real-time</i> (Method, URL, Status Code, Response Time).

Prasyarat Pengujian Lingkungan (*Environment Setup*)

1. Pengujian dilakukan menggunakan lingkungan uji lokal (*development*) menggunakan Postman atau utilitas pengujian seperti Vitest.
2. Diperlukan akses ke dasbor database (Supabase) untuk memvalidasi rekaman tabel AuditLog.
3. Server harus berjalan aktif (npm run dev) untuk melihat tangkapan *Morgan Logger* secara *real-time*.